

Enterprise AI Authentication Research • Part 7 of 7

Part 7

Standards Reference & Quick Reference Guide

OAuth 2.1, OIDC, RFC 8693, RFC 7523, implementation checklists, vendor documentation references, and decision frameworks

Enterprise Authentication & Identity Propagation for AI Agents

Key Standards Reference

This section summarises the authoritative standards that underpin enterprise AI authentication and identity propagation. Architects and engineers should read primary sources alongside this research.

OAuth 2.0 and OAuth 2.1

OAuth Standards

Standard	RFC / Spec	Key Requirements	AI Agent Relevance
OAuth 2.0 Core	RFC 6749	Authorization Code, Client Credentials, Implicit, ROPC grants	Foundation for all AI tool authentication
OAuth 2.0 Bearer Tokens	RFC 6750	Bearer token usage in Authorization header	Every AI API call uses bearer tokens
OAuth 2.1 (draft)	draft-ietf-oauth-v2-1	PKCE mandatory; Implicit + ROPC prohibited; exact redirect URI	New AI integrations should target 2.1
PKCE	RFC 7636	code_verifier, code_challenge, S256 method	Required for all public clients (AI IDEs, CLIs)
Token Introspection	RFC 7662	POST /introspect to validate opaque token	MCP servers validate user tokens at runtime
Token Revocation	RFC 7009	POST /revoke to invalidate tokens	Used on user offboarding, session termination
Dynamic Client Registration	RFC 7591	Programmatic OAuth client registration	Agent-to-agent trust establishment

OpenID Connect (OIDC)

OIDC Specifications

Specification	Purpose	Key Claims	AI Agent Use
OIDC Core 1.0	ID token format and validation	sub, iss, aud, exp, iat, nonce	User identity in ID token; passed to MCP servers
OIDC Discovery	/.well-known/openid-configuration	Authorization, token, JWKS endpoints	AI platform discovers IdP endpoints automatically
OIDC Dynamic Registration	Client registration at IdP	Client metadata, redirect URIs	AI agent self-registers with enterprise IdP

Specification	Purpose	Key Claims	AI Agent Use
OIDC Session Management	Front-channel and back-channel logout	Session state, logout endpoints	AI platform terminates session on IdP logout
OIDC FAPI 2.0	Financial-grade API profile	Strengthened OIDC for banking	Banking AI must comply with FAPI 2.0

RFC 8693 — OAuth 2.0 Token Exchange

RFC 8693 defines the 'token exchange' grant type, enabling a service to obtain a new token on behalf of another entity. This is the foundation for all On-Behalf-Of patterns in enterprise AI.

RFC 8693 Token Exchange Request Parameters

Parameter	Value / Description
grant_type	urn:ietf:params:oauth:grant-type:token-exchange
subject_token	The incoming token (user's access token to exchange)
subject_token_type	urn:ietf:params:oauth:token-type:access_token
requested_token_type	urn:ietf:params:oauth:token-type:access_token (or jwt)
audience	Target service identifier (e.g. https://graph.microsoft.com)
scope	Requested scopes for the new token
actor_token	Optional: token representing the acting service (AI platform)
actor_token_type	Optional: type of actor token

RFC 7523 — JWT Bearer Token for OAuth 2.0

RFC 7523 defines how a JWT can be used as an OAuth 2.0 grant type ('JWT Bearer') or client authentication mechanism. This enables service-to-service authentication without client secrets, using signed JWTs with short expiry instead.

RFC 7523 JWT Bearer Use Cases

Use Case	JWT Bearer Application
GitHub App authentication	GitHub App signs JWT with private key; exchanges for installation token
Salesforce JWT Bearer flow	App presents user-asserting JWT; Salesforce issues user access token
Service account assertion	AI service signs JWT claiming service identity; IdP issues access token

Use Case	JWT Bearer Application
OBO pre-authorization	Admin pre-authorizes users; app presents JWT asserting user identity

Downscoping and Scope Reduction

Downscoping is the practice of obtaining a token with reduced scopes from a broader token. This enables least-privilege tool execution: the AI platform holds a broad user token but requests narrow-scope tokens for each individual tool call.

Downscoping Patterns

Pattern	Mechanism	Example
Google Credential Downscoping	google-auth DownscopedCredentials class	Broad storage token → read-only token for specific GCS bucket
Entra OBO with limited scope	scope parameter in OBO request	Full Graph token → Files.Read.All only for SharePoint calls
AWS STS AssumeRole with policy	inline session policy in AssumeRole	Admin role → read-only S3 session for specific prefix
Kafka / OAuth scope reduction	Scope parameter in token exchange	Broad Kafka admin → specific topic read scope

Decision Frameworks

Choosing an Authentication Method for a New Connector

Use this decision framework when adding a new tool connector to an enterprise AI platform:

New Connector Authentication Decision Framework

Question	If YES →	If NO →
Does the target API support OAuth 2.0?	Use OAuth 2.0 (proceed to next question)	Consider SAML Bearer, API key, or PAT (with strict rotation)
Do you need user identity in the API call?	Use OAuth 2.0 Authorization Code + PKCE (user-delegated)	Use Client Credentials (service account); document that user identity is lost
Is this a public client (CLI, browser, IDE)?	PKCE is MANDATORY; do not use client secret	Confidential client: use client secret + PKCE
Does the target support OBO / token exchange?	Use RFC 8693 token exchange for multi-hop identity	Each hop needs separate OAuth consent; educate users
Is the token lifetime > 2 hours?	Request offline_access for refresh token; implement silent refresh	Implement re-auth prompt before token expiry
Is this a high-privilege API (write/delete)?	Require human approval gate before execution	Proceed with standard OAuth flow
Is this API in a regulated scope (PCI, SOX)?	Add OPA policy; require additional approvals; extra audit logging	Standard governance controls apply

Choosing Between Service Account and Delegated Access

Delegated vs Service Account Decision

Factor	Use Delegated (User Token)	Use Service Account
Trigger	User actively requests the action	Background task, scheduled job, indexing
Audit requirement	Must know which user did the action	System action; no specific user context needed
Permission level	User's own permissions (least privilege)	Admin-granted narrow permissions
Data access scope	User can only see what they can access	Must be explicitly restricted; risk of over-access
Compliance	Required for PCI, SOX user attribution	Acceptable for non-user-attributed background work

Factor	Use Delegated (User Token)	Use Service Account
Revocation	Token revoked when user leaves	Service account managed independently

Implementation Checklists

OAuth 2.1 Implementation Checklist

Authorization Server

- ■ Enforce PKCE (S256 method) for all clients
- ■ Prohibit implicit grant type
- ■ Prohibit Resource Owner Password Credentials grant
- ■ Enforce exact redirect URI matching
- ■ Implement refresh token rotation on each use
- ■ Support RFC 8693 token exchange for OBO
- ■ Publish /.well-known/openid-configuration
- ■ Rotate signing keys; publish JWKS at /.well-known/jwks.json

Client (AI Platform)

- ■ Generate unique code_verifier (min 43 chars, base64url encoded)
- ■ Compute code_challenge = BASE64URL(SHA256(code_verifier))
- ■ Store code_verifier only in server memory (not in browser)
- ■ Validate state parameter to prevent CSRF
- ■ Validate id_token: signature, iss, aud, exp, iat, nonce
- ■ Store tokens encrypted at rest (AES-256 + KMS)
- ■ Never log access tokens or refresh tokens
- ■ Implement silent refresh before token expiry (at 75% lifetime)

Resource Server (MCP Server / API)

- ■ Validate token: signature, iss, aud, exp, scope
- ■ Check token against revocation list (JTI blacklist or introspection)
- ■ Support Continuous Access Evaluation (CAE) claims
- ■ Log all API calls with token JTI + user sub + correlation IDs
- ■ Return WWW-Authenticate header on 401 with proper error codes
- ■ Never reflect token back in error responses or logs

MCP Server Security Checklist

- ■ Register MCP server in approved server registry; sign manifest
- ■ Validate caller identity (AI platform JWT) before processing any tool call
- ■ Validate user identity token (OAuth) before executing tool
- ■ Check OPA policy before and after tool execution
- ■ Log every tool invocation with: tool_name, user_id, args_hash, trace_id

- ■ Implement rate limiting per user per tool (e.g. 100 calls/min)
- ■ Reject tool calls with unexpected or malformed parameter schemas
- ■ Sanitize tool output before returning to AI (prevent prompt injection via results)
- ■ Use short-lived credentials for downstream API calls (not long-lived service account keys)
- ■ Implement health checks; alert on anomalous tool call patterns

Audit & Compliance Checklist

- ■ Define and document the 10-step audit chain (login → API call → response)
- ■ Implement trace_id (W3C traceparent) propagation through all components
- ■ Ensure conversation_id is included in all tool call logs
- ■ Centralise logs in SIEM (Splunk/Azure Sentinel/Chronicle)
- ■ Implement non-repudiable log storage (WORM or cryptographic chaining)
- ■ Define log retention periods per regulation (PCI: 12 months; SOX: 7 years)
- ■ Create SIEM detection rules for AI-specific threats (token exfil, prompt injection)
- ■ Schedule quarterly access reviews for AI service accounts and OAuth apps
- ■ Document AI audit trail in compliance evidence package
- ■ Test end-to-end audit trail annually (trace a sample interaction from user to API)

Vendor Documentation References

Vendor & Standards Documentation References

Topic	Source	URL / Reference
Microsoft Entra OBO	Microsoft Docs	learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-on-behalf-of-flow
M365 Copilot Architecture	Microsoft	learn.microsoft.com/en-us/copilot/microsoft-365/microsoft-365-copilot-architecture
M365 Copilot Audit	Microsoft Purview	learn.microsoft.com/en-us/purview/audit-copilot-interaction
CAE (Continuous Access Evaluation)	Microsoft	learn.microsoft.com/en-us/entra/identity/conditional-access/concept-continuous-access-evaluation
GitHub Apps Auth	GitHub Docs	docs.github.com/en/apps/creating-github-apps/authenticating-with-a-github-app
GitHub Audit Log	GitHub Docs	docs.github.com/en/organizations/keeping-your-organization-secure/reviewing-the-audit-log
Atlassian OAuth 2.0 3LO	Atlassian Docs	developer.atlassian.com/cloud/jira/platform/oauth-2-3lo-apps
Forge Security	Atlassian	developer.atlassian.com/platform/forge/security-overview
ServiceNow OAuth	ServiceNow Docs	docs.servicenow.com/bundle/latest/page/administer/security/concept/c_OAuthApplications.html
Amazon Q Business Auth	AWS Docs	docs.aws.amazon.com/amazonq/latest/qbusiness-ug/security.html
Anthropic MCP Spec	Anthropic	modelcontextprotocol.io
MCP Security	MCP Spec	modelcontextprotocol.io/docs/concepts/security
Google A2A Protocol	Google	developers.googleblog.com/2025/04/a2a-protocol.html
Salesforce OAuth Flows	Salesforce Docs	help.salesforce.com/s/articleView?id=sf.remoteaccess_oauth_flows.htm
RFC 6749 OAuth 2.0	IETF	datatracker.ietf.org/doc/html/rfc6749

Topic	Source	URL / Reference
RFC 7636 PKCE	IETF	datatracker.ietf.org/doc/html/rfc7636
RFC 8693 Token Exchange	IETF	datatracker.ietf.org/doc/html/rfc8693
RFC 7523 JWT Bearer	IETF	datatracker.ietf.org/doc/html/rfc7523
OAuth 2.1 Draft	IETF	datatracker.ietf.org/doc/draft-ietf-oauth-v2-1
OIDC Core 1.0	OpenID Foundation	openid.net/specs/openid-connect-core-1_0.html
OIDC FAPI 2.0 (Banking)	OpenID Foundation	openid.net/specs/fapi-2_0-security-profile.html
NIST SP 800-63B	NIST	pages.nist.gov/800-63-4/sp800-63b.html
OPA (Open Policy Agent)	OPA	www.openpolicyagent.org/docs/latest
AWS Cedar Policy Language	AWS	docs.cedarpolicy.com
Zero Trust Architecture	NIST SP 800-207	csrc.nist.gov/publications/detail/sp/800-207/final

Glossary

Glossary of Terms

Term	Definition
OAuth 2.0	Industry-standard protocol for delegated authorization; enables apps to access resources on behalf of users
OAuth 2.1	Consolidated update to OAuth 2.0; mandates PKCE, prohibits implicit flow and ROPC
PKCE	Proof Key for Code Exchange (RFC 7636); prevents authorization code interception attacks
OIDC	OpenID Connect; identity layer on top of OAuth 2.0; provides ID tokens with user claims
OBO	On-Behalf-Of; OAuth pattern where a service exchanges a user token for a new token for a downstream service
RFC 8693	OAuth 2.0 Token Exchange standard; formal specification for token-exchange grant type
RFC 7523	JWT Profile for OAuth 2.0 Client Authentication and Authorization Grants
MCP	Model Context Protocol; Anthropic's open standard for AI tool integration via typed tool schemas
A2A	Agent-to-Agent; Google's protocol for AI agents communicating with each other
CAE	Continuous Access Evaluation; real-time token revocation based on policy events (sub-30 second)
JWT	JWT ID claim; unique identifier for a JWT token; used for replay prevention and revocation
SAML	Security Assertion Markup Language; XML-based SSO federation standard
STS	Security Token Service; issues, validates, renews, and cancels security tokens
RBAC	Role-Based Access Control; access determined by user's assigned roles
ABAC	Attribute-Based Access Control; access determined by attributes of user, resource, environment
PBAC	Policy-Based Access Control; access determined by complex policies combining multiple factors

Term	Definition
OPA	Open Policy Agent; general-purpose policy engine with Rego policy language
Cedar	AWS Cedar policy language; purpose-built for fine-grained authorization
DWD	Domain-Wide Delegation; Google service account capability to impersonate any user in a Workspace domain
FAPI	Financial-grade API; strengthened OAuth/OIDC profile for banking and financial services
EMU	Enterprise Managed Users; GitHub feature where org controls all user accounts
CAB	Change Advisory Board; committee that approves IT change requests in ITSM frameworks
SCIM	System for Cross-domain Identity Management; protocol for automated user provisioning
PAT	Personal Access Token; long-lived credential used in place of passwords for API access
Zero Trust	Security model: never trust, always verify; authenticate and authorize every request